ETHICAL HACKING – ASSIGNMENT 1

ITA14 | Complete Answers with Expected Outputs

Design and Develop a Complete Ethical-Hacking Engagement Framework for a University's Authorized Security-Assessment Programme

Student Name: G. Anjani Kumar

Register Number: 192373022

Department: CSE(DS)

Date: 02/11/2026

Scenario and Overall Objective

The university plans to assess approximately 20 systems and 50 staff initially, including the student portal, learning-management system (LMS), email service and campus network. The programme must scale to the whole university and permit external assessors. The framework must prevent unauthorized access, reduce service disruption, protect personal data, define scope, and coordinate vulnerability disclosure.

The proposed framework uses one controlled lifecycle: request → risk and legal review → written authorization → scope and rules of engagement → lab-first validation → approved assessment → evidence handling → finding verification → coordinated disclosure → remediation and retest → closure and audit.

Core rule: authorization, legality and ethical appropriateness are separate checks. Written permission does not override law or privacy obligations, and a technically possible action is not automatically appropriate.

TASK 1 – Formulate the Enquiry and Framework Blueprint (4 Marks)

1.1 Governance requirements

Requirement area	Requirement for the university	Evidence / output
Systems	Register the student portal, LMS, email, campus network and any supporting assets. Identify owners and dependencies.	Asset register and signed scope.
Stakeholders	Identify the requester, system owner, security lead, legal/privacy representative, IT operations, assessor and disclosure contact.	Roles and responsibility matrix.
Authorization	No test begins until the authorized owner and delegated approver sign the engagement record.	Authorization form and approval log.
Scope	Specify IPs, hostnames, applications, accounts, test dates, methods, exclusions and third-party dependencies.	Rules of Engagement (RoE).

Legal/privacy	Review access permissions, personal-data handling, retention, confidentiality and applicable law before testing.	Legal/privacy checklist.
Safety	Prefer isolated-lab validation; use rate limits, maintenance windows, stop conditions and rollback plans.	Lab record and safety plan.
Disclosure	Record findings, assign severity, notify the designated owner and coordinate remediation before public disclosure.	Finding report and disclosure log.
Scalability	Use standard templates, unique engagement IDs, role-based access and periodic metrics.	Reusable document library and governance dashboard.

1.2 Stakeholders and responsibilities

Stakeholder	Responsibility
Department requester	States the business need, requested systems and desired assessment dates.
System owner	Confirms ownership, business impact, approved targets and maintenance window.
Security programme lead	Checks completeness, assigns engagement ID, coordinates the assessment and maintains records.
Legal/privacy representative	Reviews legal basis, personal-data handling, third-party contracts and disclosure risks.
Authorized assessor	Works only within scope, protects evidence, follows the code of conduct and reports findings honestly.
IT operations / incident contact	Monitors availability, supports rollback and receives urgent safety escalations.
Disclosure coordinator	Tracks notifications, remediation dates, status updates and disclosure decisions.

External assessor	Provides identity, qualifications, confidentiality commitments and signed contractual terms before access.

1.3 Enquiry questions

1. Who has authority to approve each engagement, and how is that approval verified?
2. Which assets, accounts, techniques, dates and source addresses are in scope?
3. Which Indian legal and privacy requirements apply when personal data or third-party systems are involved?
4. How will the university model likely attackers and prioritize risks?
5. How will a finding be validated, rated, reported, remediated and disclosed?
6. How will the team prove that practical testing stayed inside the authorized environment?
7. How can the framework scale to more systems and external assessors without losing accountability?

1.4 Design criteria and acceptance tests

Design criterion	Acceptance test
Authorization	Every test record has a unique ID, named approver, signed permission and valid dates.
Scope clarity	Every target is listed; an unlisted target is rejected until a scope change is approved.
Legal/privacy protection	A documented review is completed before any test involving personal data or a third party.
Safety	A stop condition, contact tree and rollback plan exist before testing.
Traceability	Approvals, test actions, findings, notifications and closure are time-stamped and auditable.
Responsible disclosure	Each finding has an owner, severity, notification date, target remediation date and status.

Scalability	The same templates and workflow support both a small department and university-wide assessments.

1.5 Framework blueprint and expected output

Blueprint: Request form → completeness check → asset-owner confirmation → legal/privacy and risk review → written authorization → RoE and pre-engagement checklist → lab rehearsal → approved assessment → evidence storage → finding report → coordinated disclosure → remediation/retest → closure and lessons learned.

Expected output: A single engagement record links the authorization form, asset scope, legal checklist, lab configuration, finding reports, disclosure log and final closure report. A missing approval or scope mismatch stops the workflow.

TASK 2 – Design a Hacker Threat Model and Classification (4 Marks)

2.1 Classification criteria

Classify an actor using four recorded dimensions: (1) authorization status, (2) intent or motivation, (3) capability and tools, and (4) target/impact. Use the actor's observed behaviour and reliable evidence rather than assumptions about identity. A person may fit more than one descriptive category, but the engagement record should select one primary category and note secondary traits.

2.2 Threat mapping table

Actor type	Motivation	Typical capability	Likely university targets	Priority / response
White-hat	Authorized security improvement	Structured testing, documentation and reporting	Portal, LMS, email, network—only when approved	Manage as a trusted assessor; still enforce scope.
Black-hat	Financial gain, theft, disruption or	Credential theft, malware, exploitation	Student records, staff accounts,	High; prevention, monitoring and

	personal benefit		payment systems	incident response.
Grey-hat	Curiosity, recognition or mixed motives; may test without permission	Variable; may discover and probe weaknesses	Public portal, exposed services	High governance concern; no testing without written authorization.
Script kiddie	Curiosity, status or disruption using ready-made tools	Low-to-moder ate; automated scans and copied scripts	Exposed web services, Wi-Fi, login pages	Harden exposed services and monitor noisy scans.
Hacktivist	Political, social or ideological cause	Defacement, DDoS, data leaks or public campaigns	Public website, email, public-facing services	Plan communications, resilience and incident response.
Insider	Grievance, profit, coercion or accidental misuse	Legitimate access that may be abused	Student/staff records, shared drives, admin tools	Least privilege, logging, separation of duties.
State-sponsor ed actor	Espionage or strategic intelligence	Persistent, well-resourced , stealthy operations	Research, identity systems, strategic data, staff email	Threat-informed monitoring and strong identity controls.

2.3 Borderline actor classification

Example: A student discovers an exposed LMS endpoint and sends a few requests without permission, then emails the security team with screenshots.

Possible classification	Reason it could fit	Decision
Grey-hat	The person tested a system without authorization but may intend to report the issue.	Primary classification because unauthorized probing occurred.

White-hat	The person later reports the weakness and may want to help.	Rejected as the primary label: good intent after discovery does not retroactively authorize testing.
Script kiddie	If copied automated tools were used, the method may resemble this category.	May be recorded as a secondary capability descriptor if evidence supports it.

Final classification: Grey-hat, unauthorized activity, low-to-moderate demonstrated capability, with a subsequent disclosure attempt. The university should preserve the report, tell the person not to continue testing, and handle the finding through its disclosure channel. The university should not invite additional probing without formal authorization.

2.4 Expected output

The threat register records actor category, evidence, motivation, capability, likely assets, impact, likelihood, controls and review date. Classification is updated when new evidence changes the assessment.

TASK 3 – Create an Ethics and Code-of-Conduct Module (4 Marks)

3.1 Code of conduct

- Written authorization: begin only after approval is signed by an authorized system owner and programme approver.
- Scope discipline: test only the listed systems, accounts, methods and time windows.
- Data minimization: view or collect only the minimum data needed to prove a finding; do not copy unrelated personal information.
- Confidentiality: store evidence in approved encrypted storage and share it only with named recipients.
- Integrity: do not alter, delete or fabricate records; maintain timestamps and evidence hashes where practical.
- Avoid harm: do not conduct destructive actions, uncontrolled denial-of-service tests or persistence on production systems.

- Honest reporting: describe methods, limitations, confidence and impact accurately; do not exaggerate severity.
- Stop and escalate: stop if a system becomes unstable, unexpected personal data is exposed, or testing reaches an out-of-scope asset.
- Respect legal and contractual obligations: authorization is not permission to ignore privacy, third-party contracts or applicable law.
- Responsible disclosure: use the university's approved reporting route and do not publish details before the disclosure decision.

3.2 Preventive checks and decision rules

Check	Pass condition	Fail action
Authorization check	Signed approval, named owner, valid dates and engagement ID exist.	Block test start.
Scope check	Target and technique appear in the approved RoE.	Stop that action; request a formal scope change.
Data check	Evidence collection is minimized and approved storage is available.	Do not collect; escalate to privacy contact.
Safety check	Monitoring, stop conditions and rollback contact are ready.	Delay testing until safeguards are ready.
Disclosure check	Finding is recorded and recipients are verified.	Do not send sensitive details to unverified recipients.

3.3 Scenario test cases

Scenario	Classification	Code-of-conduct response
Assessor runs an approved, rate-limited check on a listed lab target and records results.	Acceptable	Continue and log evidence.
Assessor sees an out-of-scope host during discovery and asks the	Acceptable	Do not test the host; request an approved scope amendment.

programme lead before proceeding.		
Assessor wants to test a production login page just outside the approved window because it is convenient.	Unacceptable unless formally re-authorized	Reject the action and record the attempted scope deviation.
A report contains a screenshot with unrelated student personal data.	Borderline / requires correction	Redact unnecessary data, restrict access and notify the privacy contact if exposure occurred.
Assessor discovers instability and immediately stops testing and contacts IT operations.	Acceptable	Follow incident procedure and document the stop.
Assessor publishes an exploitable vulnerability before notifying the university.	Unacceptable under this engagement code	Escalate to programme leadership and legal/privacy contacts.

Expected output: The code module creates a signed conduct acknowledgement and a checklist result for each engagement. Any failed mandatory check blocks or pauses the relevant activity.

TASK 4 – Construct a Legal-Compliance Mapping (4 Marks)

4.1 Applicable legal framework

For a university in India, the Information Technology Act, 2000 is a central starting point. Depending on the facts, Section 43 addresses specified unauthorized acts involving computer systems and provides for compensation; Section 66 can apply when acts described in Section 43 are done dishonestly or fraudulently; Sections 72 and 72A concern specified confidentiality/privacy-related disclosures. The Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011 may be relevant to covered body corporates and sensitive personal data. Personal-data obligations under India's Digital Personal Data Protection framework should also be reviewed for

applicability and commencement status with university counsel. Contracts, university policies, third-party terms and other applicable laws may add requirements.

International comparison: The United States Computer Fraud and Abuse Act (CFAA), 18 U.S.C. § 1030, addresses certain unauthorized access and related computer offences. It applies only where its jurisdictional requirements are met; it is not automatically the governing law for every university assessment.

4.2 Offences, obligations and controls

Law / provision	General relevance	Framework control
IT Act, Section 43	Specified unauthorized access, copying, disruption and other listed acts may create civil compensation exposure.	Written authorization, explicit target list, technique limits, monitoring and evidence logs.
IT Act, Section 66	Specified Section 43 acts done dishonestly or fraudulently may attract criminal liability.	Identity verification, signed RoE, assessor training and stop-work enforcement.
IT Act, Section 72	Can apply to specified unauthorized disclosure of information obtained through powers under the Act.	Confidentiality commitments, role-based access and controlled evidence sharing.
IT Act, Section 72A	Addresses specified disclosure of personal information in breach of lawful contract, with wrongful/loss or gain-related elements.	Contract controls, data minimization, secure storage and approved recipients.
SPDI Rules, 2011 (where applicable)	May impose requirements for covered body corporates handling sensitive personal data or information.	Privacy review, purpose limitation, safeguards and documented handling procedures.
Digital Personal Data Protection framework (where applicable)	Relevant obligations depend on the law's	Legal review before assessment; data minimization, access

	provisions, rules and commencement status.	control, retention and incident escalation.
US CFAA, 18 U.S.C. § 1030 (where jurisdiction applies)	Certain unauthorized-access and related conduct may be criminal; exact application is fact-specific.	Confirm jurisdiction and contracts; never assume Indian authorization alone resolves foreign-law issues.

4.3 Penalties and legal caveat

Penalties and liability depend on the exact provision, facts, amendments and applicable rules. Section 43 generally provides for compensation for specified acts; Section 66 has provided for imprisonment up to three years, a fine up to ₹5 lakh, or both; Section 72 has provided for imprisonment up to two years, a fine up to ₹1 lakh, or both; Section 72A has provided for imprisonment up to three years, a fine up to ₹5 lakh, or both. These are study-level summaries, not legal advice. Confirm the current statutory text and any amendments with qualified counsel before relying on figures operationally.

4.4 Decision for systems containing personal data

The university must complete a privacy and legal review before testing a system that stores personal data. Approval must identify the purpose, permitted evidence, data minimization method, access restrictions, storage location, retention period, deletion procedure and notification route. The safest default is to use synthetic or masked data in the lab. If production testing is necessary, it requires explicit written approval, a documented legal basis, strict safeguards and an agreed incident process.

Expected output: A signed legal/privacy checklist linked to the engagement ID. If jurisdiction, lawful authority or personal-data handling remains unresolved, the engagement is paused.

TASK 5 – Create a Scope and Rules-of-Engagement Document (4 Marks)

5.1 Reusable Rules of Engagement (RoE)

Field	Example / required value
Engagement ID	UNI-SEC-2026-001

Purpose	Assess security before the university systems upgrade.
In-scope assets	Only the specifically listed student portal, LMS test instance, approved email test tenant and lab network assets.
Out-of-scope assets	Unlisted IPs/domains, third-party services without written permission, personal devices, production data stores not expressly approved.
Assessment window	Approved start/end date and time; no testing outside the window.
Permitted methods	Passive review, configuration review, controlled scanning and lab-only proof-of-concept testing explicitly listed in the authorization.
Prohibited methods	Destructive testing, uncontrolled DoS, malware deployment, persistence, credential harvesting, social engineering without separate approval, data exfiltration and testing out-of-scope targets.
Source addresses/accounts	List approved tester IPs, test accounts and account privilege levels.
Safety limits	Rate limits, concurrency limits, prohibited payloads, monitoring and rollback procedure.
Contacts	System owner, programme lead, IT operations, privacy/legal contact and emergency stop contact.
Evidence handling	Minimum necessary evidence, encrypted approved storage, access log, retention deadline and secure deletion.
Change control	Any change to target, technique, timing or access requires documented approval before use.
Stop conditions	Unexpected outage, exposure of real personal data, scope ambiguity, suspected real incident or request from the designated stop authority.

5.2 Authorization verification rules

8. Verify the approver's identity and authority using the university's official directory or documented delegation.
9. Check that the signed authorization names the engagement ID, system owner, targets, dates, permitted methods and stop conditions.
10. Check signatures and approval timestamps; retain the approved version in access-controlled storage.
11. Confirm that any external assessor has a signed contract, confidentiality terms and approved access arrangements.
12. Re-verify authorization after a scope, date, assessor or technique change.
13. If any field is missing, expired or inconsistent, mark the engagement BLOCKED and do not test.

5.3 Derived pre-engagement checklist

Checklist item	Yes / No / N/A	Evidence
Engagement request is complete and has a unique ID.	____	Request form
System owner and delegated approver are verified.	____	Approval record
Written authorization is signed and in date.	____	Authorization form
Targets and exclusions match the asset register.	____	RoE and asset list
Legal/privacy review is complete.	____	Legal checklist
Testing window and rate limits are approved.	____	RoE
Lab is isolated and configuration recorded.	____	Lab record
Emergency contact and stop conditions are confirmed.	____	Contact tree
Evidence storage and retention are approved.	____	Evidence-handling plan

Assessor has acknowledged the code of conduct.	____	Signed acknowledgement

Expected output: The engagement can move to READY only when all mandatory checklist items pass. Any 'No' on authorization, scope, legal/privacy review or safety blocks the test.

TASK 6 – Build an Authorization and Disclosure Layer (5 Marks)

6.1 Authorization workflow

14. Request submitted by a department with purpose, requested assets, dates and business impact.
15. Programme coordinator checks completeness and assigns an engagement ID.
16. System owner confirms ownership, dependencies, business criticality and target list.
17. Security lead reviews risks, proposed methods, safety limits and lab-first options.
18. Legal/privacy contact reviews personal-data, contractual and jurisdictional concerns.
19. Authorized approver signs the authorization and RoE; external assessors also complete contractual and identity checks.
20. Coordinator records version, approver, timestamp, expiry and status in the approval log.
21. Pre-engagement checklist is completed; only then is the engagement marked READY.
22. Any material change requires a new approval or formally signed amendment.
23. At completion, findings are triaged, remediation is tracked, evidence is retained/deleted according to policy and the engagement is closed.

6.2 Authorization log fields

Required fields: engagement_id, requester, system_owner, approver, assessor, target_scope_version, authorization_document_reference, approval_timestamp, valid_from, valid_until, legal_review_status, privacy_review_status, RoE_version, status, change_history and closure_date.

6.3 Responsible coordinated disclosure process

Stage	Target timeline (policy proposal)	Action / record
Initial report	Day 0	Reporter sends finding through the approved channel; system creates a finding ID.
Acknowledgement	Within 2 business days	Coordinator confirms receipt and safe contact details.
Triage and validation	Within 5 business days	Security team validates safely, assigns severity and identifies affected assets.
Owner notification	Within 5 business days of validation	Notify the system owner and relevant privacy/legal contacts if data may be affected.
Remediation plan	Within 10 business days	Owner records fix, mitigation, responsible person and target date.
Remediation window	Normally 30 days for high severity; 7 days for critical-risk mitigation; up to 90 days for lower-risk fixes if justified	These are proposed internal targets, not statutory deadlines; risk and complexity can change them.
Retest	After fix is deployed	Authorized assessor verifies the fix within an approved scope.
Disclosure decision	Review at 30 days and then at agreed milestones	Coordinator considers risk, fix status, legal/privacy constraints and public harm.
Closure	After retest and approval	Record final status, lessons learned and any approved public advisory.

6.4 Disclosure approach comparison

Approach	Meaning	Advantages	Risks / suitable use
Coordinated / responsible disclosure	Reporter privately notifies the owner and coordinates a fix before public details.	Reduces user risk; gives time to remediate; supports trust.	Default for university findings, especially personal-data or high-impact issues.
Full disclosure	Details are published publicly, sometimes before a fix is available.	Can create pressure for action and inform defenders.	May enable exploitation and expose students/staff; use only after careful legal, safety and leadership review.
Bug bounty	A formal programme invites reports under published scope and rules, sometimes with rewards.	Can expand researcher participation and standardize intake.	Needs budget, triage capacity, clear scope, legal terms and duplicate-report handling.

6.5 Decision rules and integration

- Default to coordinated disclosure for all university findings.
- Do not disclose technical details publicly while a critical vulnerability remains exploitable unless a documented, authorized decision finds that disclosure is necessary and safer than silence.
- For a personal-data exposure, immediately involve the privacy/legal contact and follow applicable notification obligations; do not wait for the normal remediation window.
- Before any test or disclosure, confirm the RoE and legal review are valid. Disclosure cannot authorize further testing.
- Log every status change with actor, timestamp, reason and next action.

- If the owner misses a deadline, escalate to the security programme lead and risk owner; revise the timeline based on documented risk, not informal agreement.

Expected output: An approval log and disclosure log linked by engagement_id and finding_id. A finding cannot be closed until remediation or an accepted risk decision is recorded.

TASK 7 – Design an Isolated Ethical-Hacking Lab (5 Marks)

7.1 Lab components and network

Design a host-only virtual network using the reserved example subnet 192.168.56.0/24. Example addresses: Kali Linux tester VM 192.168.56.10/24; intentionally vulnerable target VM 192.168.56.20/24; optional logging VM 192.168.56.30/24. The host-only network has no default route to the university production network or the public Internet. Use synthetic data and snapshots.

Component	Role	Connectivity / safeguard
Host computer / hypervisor	Runs virtual machines and stores lab records.	Host-only virtual switch; patched host; restricted folder permissions.
Kali Linux VM	Authorized tester workstation.	Static IP 192.168.56.10/24; no bridged adapter; snapshots before testing.
Target VM	Training target with intentionally vulnerable services.	Static IP 192.168.56.20/24; synthetic data; no route to production.
Optional logging VM	Collects lab activity and test notes.	Static IP 192.168.56.30/24; restricted access.
Lab coordinator	Approves setup, verifies isolation and records configuration.	Signs lab checklist before hands-on work.

7.2 Configuration-recording operations

Operation A — Record lab setup:

- Record the hypervisor name/version, VM names, operating-system versions, network mode, IP addresses and snapshot identifiers.
- Save a diagram and export or screenshot the virtual network settings.
- Record date, coordinator, engagement ID, target owner and approved test window.
- Confirm no bridged adapter or unintended shared interface is enabled.
- Store the record in the engagement evidence folder.

Operation B — Verify connectivity and containment:

- From Kali, verify the target address is reachable using a basic connectivity check such as ping where ICMP is permitted.
- Confirm the target is reachable only on the host-only network and that no production or external route exists.
- If the target is unexpectedly reachable through another interface, stop and correct the configuration before testing.
- Record the command, timestamp and result; do not scan any address outside the lab's approved target list.

7.3 Host-only versus NAT

Network mode	Connectivity	Benefits	Risks / limitation	Decision
Host-only	VMs communicate with the host and other VMs on the isolated virtual network; no default Internet access.	Strong containment; suitable for vulnerable targets and repeatable labs.	May require manual updates or package transfer.	Chosen for practical security testing.
NAT	VMs can often reach external networks through the host's network address translation.	Convenient for software updates and downloads.	Outbound access can permit accidental interaction with external systems;	Use only for controlled setup/update tasks, then disconnect before testing.

			isolation is weaker.	

Expected output: A lab configuration record and connectivity test result demonstrate that hands-on testing is limited to the authorized isolated environment. Real university systems are not targets in this lab exercise.

TASK 8 – Develop a Reusable Document Library (4 Marks)

8.1 Reusable documents and required fields

Document	Required fields	Integration
1. Engagement request and authorization form	Engagement ID, requester, purpose, system owner, targets, dates, approver, signatures, legal/privacy review, expiry.	Starts the workflow and supplies approval status.
2. Rules of Engagement	Scope, exclusions, techniques, limits, accounts, test window, contacts, stop conditions, evidence rules, change control.	Used by the checklist and assessor.
3. Finding report	Finding ID, engagement ID, title, affected asset, severity, description, safe evidence, impact, reproduction summary, remediation, owner, dates, disclosure status.	Creates structured remediation and disclosure records.
4. Disclosure and remediation log	Finding ID, reporter, acknowledgement, owner notified, severity, target fix date, updates, retest result, disclosure decision, closure.	Tracks remediation and public-disclosure decisions.
5. Lab configuration record	Engagement ID, VM names, versions, IPs,	Proves test containment.

	network mode, snapshots, connectivity results, coordinator and timestamp.	

8.2 Structured finding report example

Field	Example value
finding_id	F-UNI-2026-004
engagement_id	UNI-SEC-2026-001
title	Excessive information disclosed by a test endpoint
affected_asset	LMS test instance — 192.168.56.20
severity	Medium — provisional pending owner validation
evidence	Redacted screenshot and timestamp; no unrelated personal data retained
impact	Could reveal implementation details that assist further attacks
recommended_fix	Return only required fields; enforce authorization checks; add regression tests
owner	LMS system owner
status	Reported
disclosure_status	Coordinated; not public
target_remediation_date	Within 30 days, subject to risk review

8.3 Validation test entries

Test input	Test type	Expected result
Signed authorization with valid dates and listed target	Valid	Record accepted; engagement may proceed after all other checks pass.
Authorization exists but expiry date is missing	Boundary / incomplete	Reject as incomplete; request correction.
Target IP is outside the approved scope	Invalid	Block test and require formal scope amendment.

Finding report has no finding_id or engagement_id	Invalid	Reject structured report until identifiers are supplied.
Finding report includes a redacted screenshot and severity	Valid	Accept and create remediation/disclosure tracking entries.
Disclosure log says 'closed' but has no remediation or accepted-risk decision	Invalid	Keep open and escalate for closure evidence.

Expected output: The document library uses common IDs so an authorization, RoE, lab record, finding and disclosure entry can be joined without ambiguity. A record with missing mandatory fields is not accepted.

TASK 9 – Integrate, Test and Refine the Framework (4 Marks)

9.1 End-to-end walkthrough

24. A department submits a request to assess the LMS before an upgrade.
25. The coordinator creates UNI-SEC-2026-001 and confirms the LMS test instance owner.
26. The legal/privacy review specifies synthetic data and evidence minimization.
27. The approver signs the authorization and RoE, listing only the lab target and approved methods.
28. The lab coordinator records the host-only network and verifies Kali can reach the target VM.
29. The assessor performs only the approved lab tests and records timestamped evidence.
30. A finding F-UNI-2026-004 is submitted with severity, impact and remediation guidance.
31. The disclosure coordinator acknowledges the report, notifies the LMS owner and sets a remediation target.
32. The owner applies a fix; the assessor retests under the approved scope.
33. The coordinator records the result, closes the finding after verification and archives/deletes evidence according to policy.

9.2 Systematic test cases

Test case	Expected system behaviour	Result
Missing authorization	Engagement remains BLOCKED; no testing begins.	Pass if blocked.
Out-of-scope target requested	Action is rejected; scope-change approval required.	Pass if no probing occurs.
Legal/privacy conflict unresolved	Engagement pauses until counsel/privacy review resolves it.	Pass if paused.
Critical finding and delayed owner response	Escalation occurs; mitigation and disclosure decision are documented.	Pass if escalated and logged.
Assessor tries to test after expiry	Authorization check fails and test is stopped.	Pass if blocked.
Lab has unintended bridged adapter	Containment check fails; practical work is prohibited until fixed.	Pass if stopped.

9.3 Problems found and refinements

Problem during walkthrough	Refinement	Evidence of improvement
A request listed a product name but not a precise target.	Require hostname/IP, owner and environment for every target.	Out-of-scope test case is rejected.
A disclosure deadline was not linked to finding severity.	Set default severity-based targets and escalation reminders.	Disclosure log has target dates and escalation status.
A report could be closed without retest evidence.	Require retest result or formally accepted risk before closure.	Invalid closure test fails.
Lab configuration could drift between sessions.	Require a configuration record and snapshot ID before every session.	Lab checklist verifies the recorded state.

External assessor responsibilities were unclear.	Add identity verification, confidentiality and access-expiry checks.	Authorization checklist includes external assessor checks.

Expected output: The integrated framework blocks unsafe starts, routes findings to the correct owner and produces an auditable record from request to closure.

TASK 10 – Create a Scalability and Governance Evaluation (4 Marks)

10.1 Evaluation scenarios

Measure	Small programme	University-wide programme
Scope	One department; 3 systems	Whole university; 20 systems initially, designed to scale
People	1 requester, 1 owner, 1 internal assessor, 1 approver	Multiple owners, security team, privacy/legal, IT operations and internal/external assessors
Approval process	One coordinated review	Role-based parallel reviews with a central status tracker
Scope management	One concise asset list	Versioned asset register, owner mapping and third-party exclusions
Disclosure	One coordinator may handle all findings	Central triage queue with severity-based assignment and escalation

10.2 Illustrative process measures

The following figures are an illustrative tabletop simulation for the assignment, not measured results from a live university. They show how the team could evaluate the workflow.

Process measure	Small programme (3 systems)	Large programme (20 systems)	Interpretation

Approval turnaround	2 business days	5 business days	More stakeholders increase review time; parallel review and templates can reduce delay.
Scope validation steps	5 steps	7 steps	Large scope needs owner mapping and third-party dependency checks.
Checklist completion	10 items	10 items plus external-assessor checks	Core controls stay constant; additional checks are conditional.
Initial triage after finding	1 business day	2 business days	A shared queue and severity-based routing prevent findings from being missed.
Scope coverage	3 of 3 listed systems (100%)	18 of 20 listed systems (90%) in the illustrative run	A coverage dashboard exposes unassessed assets and prevents false claims of complete coverage.

10.3 Simple text chart: approval turnaround

Illustrative approval turnaround (business days):

Small programme ■■ 2 days

University-wide ■■■■■ 5 days

10.4 Governance refinements from the evaluation

- Use a standard request form and pre-approved low-risk test profiles to reduce repeated clarification.
- Route legal/privacy, system-owner and security reviews in parallel when their inputs are independent.

- Use a central dashboard to display pending approvals, asset coverage, open findings and overdue remediation.
- Require explicit owner sign-off for every asset; do not treat an untested asset as covered.
- Use severity-based triage and automatic escalation reminders while retaining human approval for high-risk disclosure decisions.

Expected output: A reproducible evaluation table and chart support the decision to centralize tracking while preserving local system-owner approval. The example measures must be replaced by actual observations if the university performs a real tabletop exercise.

TASK 11 – Defend the Framework Under a Changed Requirement (4 Marks)

11.1 Changed requirement

The university now needs continuous assessments, third-party assessors, stricter data-protection controls, a shorter disclosure timeline and a framework that remains easy to govern and extend.

11.2 Retain, modify, replace or redesign

Component	Decision	Reason / change
Written authorization	Retain and strengthen	Use time-limited approvals, asset-owner delegation, assessor identity checks and periodic revalidation.
Asset scope and RoE	Modify	Use versioned scope records, per-asset owners, approved recurring windows and automatic expiry.
Legal/privacy review	Strengthen	Require data classification, minimum-evidence rules, retention/deletion plan and third-party data-transfer review.

Disclosure process	Redesign	Shorten acknowledgement and triage targets; add critical-risk immediate escalation and daily overdue review.
Isolated lab	Retain and extend	Use repeatable VM templates, snapshots and synthetic data; keep production systems out of lab exercises.
Document library	Replace manual-only tracking with controlled digital records	Use role-based access, audit history, unique IDs and status reminders.
Governance evaluation	Extend	Measure recurring coverage, time-to-triage, overdue findings, external-assessor compliance and retest success.

11.3 New component: Continuous Assessment Control

Create a Continuous Assessment Register with the following fields: assessment_id, asset_id, owner, approved test profile, allowed frequency, approved time window, source address, assessor identity, authorization expiry, data classification, rate limit, last run, next run, result summary, open critical findings, stop flag and review date.

Operational rules:

- Recurring assessments are allowed only for assets and methods explicitly covered by a current signed authorization.
- Every run checks scope version, expiry, assessor identity and stop flag before starting.
- Automated checks use safe rate limits and exclude destructive tests by default.
- A critical finding triggers immediate notification to the security lead and owner; potentially affected personal data also triggers privacy/legal review.
- Third-party assessors receive least-privilege, time-limited access and must use approved evidence storage.

- The register creates a finding and disclosure record automatically, but a human owner validates severity and approves public disclosure.
- Expired authorization, scope mismatch, unexplained data exposure or system instability stops the run.

11.4 Shorter disclosure timeline

Event	Revised internal target	Escalation
Critical finding reported	Immediate acknowledgement target; triage within 4 hours where staffed	Notify security lead and system owner immediately.
High-severity finding	Acknowledge within 1 business day; triage within 1 business day	Escalate if no owner is assigned by end of day.
Medium/low finding	Acknowledge within 2 business days; triage within 5 business days	Track in the central queue.
Possible personal-data exposure	Immediate containment and privacy/legal escalation	Follow applicable legal and contractual notification duties.
Overdue remediation	Review at each milestone and at least weekly for high-risk items	Risk owner documents mitigation, accepted risk or further escalation.

These are proposed internal service targets, not statements of statutory deadlines. Applicable legal reporting timelines must be separately confirmed.

11.5 Defence, trade-offs and future improvements

The framework is defensible because the walkthrough demonstrates an end-to-end chain from request to closure; the scalability exercise shows how shared templates and parallel reviews can reduce coordination overhead; the legal mapping introduces a mandatory review before personal-data handling; and the disclosure process assigns owners, dates and escalation rules.

Trade-off 1: Strong approval controls may delay urgent assessments. Improvement: define delegated approvers and pre-approved low-risk test profiles, while keeping high-risk methods under explicit review.

Trade-off 2: Automated continuous checks can generate false positives or operational load. Improvement: pilot each profile in the lab, tune rate limits, measure false-positive rates and require human validation for significant findings.

Trade-off 3: External assessors improve capacity but increase access and confidentiality risk. Improvement: use time-limited accounts, contractual obligations, least privilege, audit logs and post-engagement access revocation.

Trade-off 4: A shorter disclosure window can conflict with the time needed to build a safe fix. Improvement: prioritize immediate mitigation for critical risk, communicate status transparently and make disclosure decisions through a documented risk review.

Expected output: A revised continuous-assessment component integrated with authorization, RoE, legal/privacy review, finding reports and disclosure tracking.

Final Framework Acceptance Checklist

Acceptance requirement	Evidence in this assignment	Status
Authorization is mandatory	Tasks 1, 5 and 6: approval workflow and verification rules	Designed
Scope is explicit and enforceable	Task 5: in-scope/out-of-scope rules and checklist	Designed
Threat actors are classified consistently	Task 2: criteria, mapping and borderline example	Designed
Ethics controls are testable	Task 3: code, decision rules and scenarios	Designed
Legal/privacy risks are mapped to controls	Task 4: legal mapping and privacy decision	Designed; counsel verification required
Lab testing is isolated	Task 7: host-only topology and verification operations	Designed
Documents connect through common IDs	Task 8: reusable forms and structured finding record	Designed

End-to-end workflow is tested	Task 9: walkthrough, failure cases and refinements	Tabletop-designed
Scalability is evaluated	Task 10: illustrative measures, comparison and chart	Illustrative simulation
Changed requirements are addressed	Task 11: continuous-assessment control and shorter internal targets	Designed

References for Further Verification

- Information Technology Act, 2000 (India), including Sections 43, 66, 72 and 72A. Consult the current official text and amendments.
- Information Technology (Reasonable Security Practices and Procedures and Sensitive Personal Data or Information) Rules, 2011, where applicable.
- Digital Personal Data Protection Act, 2023 and applicable rules/commencement notifications. Confirm current applicability with university counsel.
- United States Code, 18 U.S.C. § 1030 (Computer Fraud and Abuse Act), where jurisdictionally applicable.
- University policies, system-owner approvals, third-party contracts and internal incident-response procedures.

End of Assignment 1 Answers.